Lab 42 — Digital Forensics: Acquisition & Chain of Custody

> **SY0-701 Objective 4.8** — Explain appropriate incident response activities.
>
> **Domain 4** — Security Operations (28%) · **Time:** ~15 min · **Course:** TGS-2023039181 CompTIA Security+ (SY0-701)

Goal: acquire a forensically sound image of a suspect disk, prove its integrity with hashes before and after, examine it read-only and keep an unbroken chain of custody.

You'll build: a legal hold notice, a chain-of-custody log, volatile-data captures, a write-protected loop-device "suspect disk", `dd` and `dcfldd` images with matching SHA-256 hashes, recovered deleted artefacts and a short forensic report.

Prerequisites: Killercoda Ubuntu Playground (root shell) — https://killercoda.com/playgrounds/scenario/ubuntu ; Lab 41 (incident response) is useful background; tools installed in step 1.

Background

- **Legal hold** is the instruction, usually from legal counsel, to suspend normal deletion and retention rotation for anything relevant once litigation or an investigation is anticipated.
- **Order of volatility** sets the collection sequence: CPU registers and cache, then memory, network and process state, temporary files and swap, disk, remote logs, and finally archival media.
- **Acquisition** produces a bit-for-bit image, never a file copy, through a hardware or software **write blocker**. Hash the source and the image; matching SHA-256 values prove the copy is exact.
- **Chain of custody** records who handled each item, when, why and where it was stored. One undocumented gap can make the evidence inadmissible.
- **Preservation** keeps the original sealed and unchanged while all analysis happens on verified copies. **Reporting** documents the method, findings and hashes so another examiner can reproduce them. **E-discovery** is the legal process of finding, preserving and producing electronically stored information.

Steps

1. Install the tools

`dcfldd` is the forensic version of `dd` with on-the-fly hashing, The Sleuth Kit lists files including deleted ones, and `foremost` carves files out of raw data by their header and footer signatures.

```
apt-get update -qq && DEBIAN_FRONTEND=noninteractive apt-get install -y dcfldd sleuthkit
foremost e2fsprogs
mkdir -p /cases/CASE-042/{evidence,images,work,reports}
```

2. Open the case: legal hold and chain-of-custody form

Before touching anything, record the legal hold and start the custody log. Every later step appends a line to it.

```
cd /cases/CASE-042
cat > reports/legal-hold-notice.txt <<EOF
LEGAL HOLD NOTICE - CASE-042          Issued: $(date -u +%F)
Matter: suspected leak of Project Nightfall plans (synthetic exercise)
Custodians: J. Doe (finance), IT operations
Scope: laptop disk FIN-LT-0457, mailbox jdoe, file share /finance
Instruction: suspend all deletion, re-imaging and log rotation for the scope above until
released in writing by Legal.
EOF
printf 'utc_time,item_id,action,handler,location,sha256\n' > reports/chain-of-custody.csv
echo "$(date -u +%FT%TZ),FIN-LT-0457,received under legal hold,$(whoami),evidence locker
A3," >> reports/chain-of-custody.csv
cat reports/legal-hold-notice.txt
```

3. Capture volatile data first (order of volatility)

On a live system, memory and network state disappear when the machine is powered off, so capture them before anything else. Here you capture system time, processes, connections and logged-in users, and hash them at once.

```
cd /cases/CASE-042/evidence
date -u +%FT%TZ > v01-system-time.txt; uptime >> v01-system-time.txt
ps auxww > v02-processes.txt
ss -tunap > v03-network.txt; ip neigh > v03-arp.txt
who -a > v04-users.txt
sha256sum v0* | tee volatile.sha256
echo "$(date -u +%FT%TZ),VOL-001,volatile data captured,$(whoami),/cases/CASE-
042/evidence,$(sha256sum volatile.sha256 | cut -d' ' -f1)" >> ../reports/chain-of-
custody.csv
```

4. Create the suspect disk and write-protect it

A 32 MB file attached as a loop device stands in for the seized drive. You place some files on it, delete two of them (as the suspect did), then set the device read-only with `blockdev --setro`, which acts as a software write blocker.

```
dd if=/dev/zero of=/cases/CASE-042/FIN-LT-0457.raw bs=1M count=32 status=none
LOOP=$(losetup -f --show /cases/CASE-042/FIN-LT-0457.raw) && echo "$LOOP" > /cases/CASE-
042/loopdev
mkfs.ext4 -q -L FIN-LT-0457 "$LOOP"
mkdir -p /mnt/suspect && mount "$LOOP" /mnt/suspect
echo "Quarterly budget - nothing sensitive" > /mnt/suspect/budget.txt
echo "CONFIDENTIAL: Project Nightfall launch plan - send to competitor contact" >
/mnt/suspect/nightfall.txt
printf '\xff\xd8\xff\xe0\x00\x10JFIF\x00\x01\x01\x00\x00\x01\x00\x01\x00\x00NIGHTFALL-
BLUEPRINT\xff\xd9' > /mnt/suspect/blueprint.jpg
sync; rm /mnt/suspect/nightfall.txt /mnt/suspect/blueprint.jpg; sync
umount /mnt/suspect
blockdev --setro "$LOOP" && blockdev --getro "$LOOP"
```

```
1
```

5. Hash the source before acquisition

Hash the original media first. This value is the reference that every copy must match.

```
LOOP=$(cat /cases/CASE-042/loopdev)
sha256sum "$LOOP" | awk '{print $1}' | tee /cases/CASE-042/reports/source-before.sha256
echo "$(date -u +%FT%TZ),FIN-LT-0457,source hashed before acquisition,$(whoami),write-
blocked $LOOP,$(cat /cases/CASE-042/reports/source-before.sha256)" >> /cases/CASE-
042/reports/chain-of-custody.csv
```

6. Acquire bit-for-bit images with dd and dcfldd

`dd` makes a raw image; `conv=noerror,sync` keeps going past bad sectors and pads them so offsets stay correct. `dcfldd` hashes while it copies and writes the hash to a log.

```
cd /cases/CASE-042 && LOOP=$(cat loopdev)
dd if="$LOOP" of=images/FIN-LT-0457.dd bs=1M conv=noerror,sync status=none
dcfldd if="$LOOP" of=images/FIN-LT-0457.dcfldd.img bs=1M hash=sha256
hashlog=reports/dcfldd-hash.log
cat reports/dcfldd-hash.log
```

7. Verify the images and record them in the chain of custody

Hash both images and the source again. All values must be identical; if the source hash changed, the write blocker failed.

```
cd /cases/CASE-042 && LOOP=$(cat loopdev)
sha256sum images/FIN-LT-0457.dd images/FIN-LT-0457.dcfldd.img | tee reports/images.sha256
sha256sum "$LOOP" | awk '{print $1}' > reports/source-after.sha256
diff reports/source-before.sha256 reports/source-after.sha256 && echo "SOURCE UNCHANGED"
[ "$(awk '{print $1}' reports/images.sha256 | sort -u | wc -l)" = 1 ] && grep -q "$(cat
reports/source-before.sha256)" reports/images.sha256 && echo "IMAGES MATCH SOURCE"
echo "$(date -u +%FT%TZ),IMG-001,dd image created and verified,$(whoami),/cases/CASE-
042/images,$(cut -d' ' -f1 reports/images.sha256 | head -1)" >> reports/chain-of-
custody.csv
```

8. Examine a working copy read-only and recover deleted artefacts

Never analyse the original or the master image. Make a working copy, mount it read-only with `noload` (so the ext4 journal is not replayed), then look for deleted entries and carve data out of unallocated space.

```
cd /cases/CASE-042
cp images/FIN-LT-0457.dd work/working-copy.dd
mkdir -p /mnt/case042 && mount -o ro,noload,loop work/working-copy.dd /mnt/case042
ls -la /mnt/case042
fls -r -d work/working-copy.dd
grep -a -o 'CONFIDENTIAL: Project Nightfall.*competitor contact' work/working-copy.dd |
head -1
printf 'jpg y 200000 \\xff\\xd8\\xff\\xe0\\x00\\x10 \\xff\\xd9\n' > work/foremost.conf
foremost -q -c work/foremost.conf -i work/working-copy.dd -o work/carved && ls -R
```

```
work/carved | head
umount /mnt/case042
sha256sum images/FIN-LT-0457.dd | cut -d' ' -f1 | grep -q "$(cat reports/source-
before.sha256)" && echo "MASTER IMAGE STILL INTACT"
```

```
budget.txt  lost+found
d/d *  12:   nightfall.txt   (deleted entries; names vary by inode reuse)
CONFIDENTIAL: Project Nightfall launch plan - send to competitor contact
work/carved/jpg: 00000xxx.jpg
MASTER IMAGE STILL INTACT
```

9. Preserve the evidence and write the report

Seal the master image (read-only and immutable), detach the suspect device and write a report another examiner could reproduce.

```
cd /cases/CASE-042
chmod 0444 images/* && chattr +i images/FIN-LT-0457.dd 2>/dev/null; lsattr images/
2>/dev/null
losetup -d "$(cat loopdev)"
echo "$(date -u +%FT%TZ),IMG-001,master image sealed (0444 +
immutable),$(whoami),/cases/CASE-042/images," >> reports/chain-of-custody.csv
cat > reports/forensic-report.txt <<EOF
CASE-042 forensic acquisition report        $(date -u +%FT%TZ)
Media: FIN-LT-0457 (32 MB ext4), write-blocked with blockdev --setro
Source SHA-256 before: $(cat reports/source-before.sha256)
Source SHA-256 after:  $(cat reports/source-after.sha256)
Images: dd and dcfldd, both hashes equal to the source
Findings: deleted file nightfall.txt content recovered from unallocated space;
          deleted JPEG carved by foremost (work/carved/jpg)
Method: analysis on a working copy mounted ro,noload; master image sealed
Chain of custody: reports/chain-of-custody.csv
EOF
cat reports/forensic-report.txt; column -s, -t < reports/chain-of-custody.csv
```

Test it

```
cd /cases/CASE-042
sha256sum -c reports/images.sha256
grep -c . reports/chain-of-custody.csv
ls work/carved/jpg/ | wc -l
```

Expected: both image lines report `OK`, the custody log has at least six lines (header plus five entries) and foremost carved at least one JPEG.

Troubleshooting

Symptom	Fix
`losetup: cannot find an unused loop device`	Load the module with `modprobe loop`, or check `losetup -a` and detach stale devices with `losetup -d /dev/loopN`.

Symptom	Fix
`mount: wrong fs type` or "cannot mount read-only" on the working copy	Include `noload`: a dirty ext4 journal needs replay, which a read-only mount refuses. Use `mount -o ro,noload,loop`.
foremost carves nothing	Make sure step 4 ran `sync` before deleting, and run foremost against the image, not the mounted folder. Delete `work/carved` first because foremost needs an empty output folder.

Challenge

Acquire the same suspect device into a compressed, split evidence set with `dcfldd ... split=8M splitformat=aa`, then reassemble it with `cat` and prove with SHA-256 that the reassembled image matches the original source hash.

Reflection

Opposing counsel claims your evidence was altered after seizure. Which three records from this lab would you produce, and what does each prove?

Exam tips

- Legal hold preserves; e-discovery finds and produces; chain of custody proves who handled the evidence; hashing proves integrity.
- Order of volatility: memory and network state before disk, disk before remote logs and backups.
- Image the drive (bit-for-bit, through a write blocker) rather than copying files: a file copy misses deleted data and slack space.
- Analyse only verified copies; the original is preserved and sealed.

References

- NIST SP 800-86 Guide to Integrating Forensic Techniques into Incident Response — https://csrc.nist.gov/pubs/sp/800/86/final
- RFC 3227 Guidelines for Evidence Collection and Archiving (order of volatility) — https://datatracker.ietf.org/doc/html/rfc3227
- The Sleuth Kit documentation — https://www.sleuthkit.org/sleuthkit/docs.php
- dcfldd project — https://github.com/resurrecting-open-source-projects/dcfldd

---